

BimaKavach — Technical Debt Audit

BimaKavach — Technical Debt Audit

Scope: Full platform — all microservices, frontends, POS, infrastructure, and scripts

Table of Contents

- [1. Executive Summary](#)
 - [2. Critical Security Issues](#)
 - [2.1 Committed Secrets & Credentials](#)
 - [2.2 Hardcoded API Secrets in Source Code](#)
 - [2.3 Weak Cryptography](#)
 - [2.4 XSS Vulnerabilities](#)
 - [2.5 Insecure Token Storage](#)
 - [3. Architecture & Design Debt](#)
 - [3.1 God Classes / Massive Files](#)
 - [3.2 Fire-and-Forget Async Patterns](#)
 - [3.3 Sleep/setTimeout Hacks](#)
 - [3.4 Tightly Coupled External Integrations](#)
 - [3.5 Missing Message Queue / Event System](#)
 - [4. Code Quality Debt](#)
 - [4.1 TypeScript Type Safety](#)
 - [4.2 Console Logging in Production](#)
 - [4.3 Error Handling Anti-Patterns](#)
 - [4.4 Code Duplication](#)
 - [4.5 Unsafe JSON Parsing](#)
 - [4.6 Hardcoded Magic Numbers & Constants](#)
 - [4.7 TODO/FIXME Comments](#)
 - [4.8 ESLint Suppression](#)
 - [5. Dependency Debt](#)
 - [5.1 Deprecated Libraries](#)
 - [5.2 Outdated Versions](#)
 - [5.3 Redundant Dependencies](#)
 - [6. Frontend-Specific Debt](#)
 - [6.1 No TypeScript in BK Web](#)
 - [6.2 Missing Error Boundaries](#)
 - [6.3 State Management Bloat](#)
 - [6.4 Mixed UI Libraries in bi-admin](#)
 - [6.5 Missing Accessibility](#)
 - [7. Infrastructure & DevOps Debt](#)
 - [7.1 Outdated Docker Base Images](#)
 - [7.2 Missing Health Checks](#)
 - [7.3 Docker Build Issues](#)
 - [7.4 SSL/TLS Verification Disabled](#)
 - [7.5 No Secrets Management](#)
 - [8. Testing Debt](#)
 - [9. Priority Matrix](#)
-

1. Executive Summary

This audit covers the entire BimaKavach platform: 6 backend microservices, 5 frontend/mobile apps, Docker infrastructure, and supporting scripts. The findings are categorized by severity and type.

Key Statistics

Metric	Count
Committed <code>.env</code> files with real secrets	17
Hardcoded credentials in source code	15+
Files with <code>console.log</code> in production code	120+
Files with <code>any</code> type usage (backend)	100+
God-class files (>1000 lines)	25+
<code>dangerouslySetInnerHTML</code> without sanitization	24
Missing Docker health checks	9 services
Deprecated libraries in use	5

Severity Breakdown

Severity	Count	Description
CRITICAL	8	Active security vulnerabilities — credentials exposed, XSS, weak crypto
HIGH	12	Architectural debt causing reliability/maintainability issues
MEDIUM	15	Code quality issues increasing bug risk and slowing development
LOW	8	Cleanup items that improve developer experience

2. Critical Security Issues

2.1 Committed Secrets & Credentials

Severity: CRITICAL

17 `.env` files are committed to the repository with real production/staging credentials. Additionally, credential backup files exist at the repository root.

Exposed credentials include:

Secret Type	Files	Example
AWS S3 Access Keys	5 <code>.env</code> files	<code>AKIA3FYJPYEJFNCE2UNS</code>
SendGrid API Key	4 <code>.env</code> files	<code>SG.wQSpJ0AvQQ-z56oHtjF-cw...</code>
LeadSquared API Keys	4 <code>.env</code> files	Access ID + Secret Key
Database Passwords	6 <code>.env</code> files	Including production RDS credentials
JWT Secrets	3 <code>.env</code> files	<code>fsbfu843#@%^&#@GHVDSGH</code>
Firebase Private Key	2 <code>.env</code> files	Full PEM certificate
Google Cloud Private Key	2 <code>.env</code> files	Full PEM certificate
Sibro Auth Token	2 <code>.env</code> files	Bearer token
OpenAI API Key	<code>reporting-engine-v2/.env</code>	<code>sk-proj-WpNeIMBR...</code>
Gemini API Key	<code>microservice-question/.env</code>	<code>AIzaSyCuFwmH...</code>
MSG91 Auth Key	2 <code>.env</code> files	OTP service credentials
Probe API Key	<code>microservice-api-gateway/.env</code>	Company verification API
Gmail App Password	<code>docker-monitor/.env</code>	<code>wmum qxdf cdwj meeo</code>
Encryption Keys	<code>microservice-api-gateway/.env</code>	HMAC + AES keys

Root-level credential files:

File	Contents
<code>old-credentials-backup.json</code>	iOS/Android keystore passwords
<code>playstore-upload-key-BACKUP.jks</code>	Play Store signing key backup
<code>old-credentials-backup/</code>	Directory with iOS dist-certs and Android keystores

Remediation: 1. Rotate ALL exposed credentials immediately 2. Remove `.env` files from git history (`git filter-repo`) 3. Add `.env` to `.gitignore` across all repos 4. Adopt AWS Secrets Manager or similar vault 5. Delete `old-credentials-backup*` files and `playstore-upload-key-BACKUP.jks`

2.2 Hardcoded API Secrets in Source Code

Severity: CRITICAL

Credentials are hardcoded directly in source code (not just `.env` files):

File	Line(s)	Secret
microservice-api-gateway/src/global-constants/Constants.ts	174-175	Merchant keys (UAT + PROD): j07@vcYwD7co0h5b , tKHGWWW#3Lz@TAXP
microservice-common/src/tp-quote-calculation/tp-quote-calculation.service.ts	32-33	Chola Insurance Basic Auth (Base64)
microservice-common/src/tp-quote-calculation/tp-quote-calculation.service.ts	67-68	Tata AIG OAuth2 client_id + client_secret
BK_Web_V2.0/services/clientService.js	7	API_SECRET = "bimakavach-open-api"
bi-admin-V2/src/utils/auth.ts	46	Same API_SECRET duplicated
bi-admin-V2/src/redux/features/apiSlice.ts	6	Same API_SECRET duplicated again
pos/pos-admin/src/lib/auth.ts	7	Same API_SECRET duplicated again
microservice-question/src/sibro/services/sibro-client.service.ts	56-63	Hardcoded Sibro API URLs

The `API_SECRET = "bimakavach-open-api"` is duplicated in **6 different files** across 4 repos.

2.3 Weak Cryptography

Severity: CRITICAL

File	Line	Issue
microservice-question/Dockerfile	4	<code>ENV NODE_OPTIONS=--openssl-legacy-provider</code> — disables modern crypto, enables deprecated algorithms
microservice-question/src/utils/index.ts	173	DES encryption with hardcoded key derivation — DES is deprecated and weak (56-bit effective key)

2.4 XSS Vulnerabilities

Severity: HIGH

24 files use `dangerouslySetInnerHTML` without input sanitization:

App	Files	Example
BK_Web_V2.0	20	CoverageDetailsCard.js , TestimonialSection , NewsSliderCard , ProductSeoContent , etc.
bi-admin-V2	4	TableCard , TimelineCard , TreeView , insurer-cover-list page

If any of this data originates from user input or external APIs, it's a direct XSS vector.

2.5 Insecure Token Storage

Severity: HIGH

App	Storage	File	Issue
BK_Web_V2.0	sessionStorage	services/clientService.js:29–43	JWT + refresh token in sessionStorage (accessible to XSS)
BK_Web_V2.0	document.cookie	services/clientService.js:40	Token in non-httpOnly cookie
bi-admin-V2	sessionStorage	src/utls/auth.ts:87	Token stored as plain JSON string
pos/pos-app	AsyncStorage	src/store/authStore.ts:2	AsyncStorage is NOT encrypted on device

Remediation: Use httpOnly secure cookies for web apps, and expo-secure-store exclusively for mobile.

3. Architecture & Design Debt

3.1 God Classes / Massive Files

Severity: HIGH

Files exceeding 1000 lines violate Single Responsibility Principle. They are hard to test, review, and maintain.

Backend:

File	Lines	Responsibilities Mixed
microservice-api-gateway/src/lead-square/lead-square.service.ts	7,933	Lead CRUD, opportunities, activities, policy creation, renewals, documentation, CSV processing
microservice-question/src/quotes/quotes.service.ts	4,745	Quote creation, PDF generation, KYC, Chola integration, payment handling
microservice-api-gateway/src/users/users.service.ts	3,229	User CRUD, OTP, auth, company management, bulk uploads, LSQ integration
microservice-question/src/policy-upload/policy.service.ts	2,874	Policy management, email triggers, endorsements, renewals
microservice-api-gateway/src/lead-square/services/lead-square-lapp.service.ts	2,512	CSV processing, lead transformation
microservice-question/src/qcr/qcr.service.ts	2,136	QCR processing, PDF generation, Excel export
microservice-common/src/tp-quote-calculation/tp-quote-calculation.service.ts	1,868	Third-party quote calculations for multiple insurers
microservice-api-gateway/src/users/company.service.ts	1,765	Company management mixed with multiple concerns
microservice-email/src/email/email.service.ts	1,565	Template rendering, sending, scheduling, PDF conversion
microservice-question/src/sibro/services/sibro-client.service.ts	1,450	All Sibro integration with 9 repositories injected
microservice-question/src/client-answer/client-answer.service.ts	1,153	Client answer processing
microservice-api-gateway/src/routers/quote.controller.ts	1,005	Controller doing too much business logic

Frontend:

File	Lines	Issue
BK_Web_V2.0/staticData/v3/faq.js	2,381	Static data in code instead of CMS/DB
BK_Web_V2.0/ContextAPI/PurchaseFlowContext.js	2,219	Massive Context API — state management bloat
BK_Web_V2.0/component/L1QuestionForm/index.js	2,105	Monolithic form component
pos/pos-app/src/app/(tabs)/quotes/[quoteId].tsx	2,055	Single page handling full quote flow
BK_Web_V2.0/component/v4/Homepage/InsuranceBrokenSection/index.js	1,458	Single UI section
bi-admin-V2/src/app/dashboard/client/edit-client-policy/page.tsx	1,622	Monolithic page component
pos/pos-admin/src/components/policies/PolicyForm.tsx	1,473	Large form component
bi-admin-V2/src/app/dashboard/renewal-details/add/page.tsx	1,423	Monolithic page
pos/pos-admin/src/components/settings/PolicyStatusManagement.tsx	1,215	Settings management
pos/pos-admin/src/components/conversations/ConversationActivityPanel.tsx	1,201	Activity panel
pos/pos-admin/src/components/policies/PolicyActionForm.tsx	1,151	Action form
pos/pos-app/src/services/quotePdfService.ts	1,098	PDF generation logic

3.2 Fire-and-Forget Async Patterns

Severity: HIGH

Multiple controllers use `setImmediate` to run background work with only `console.error` as error handling. If these fail, there's no retry, no monitoring, and no visibility.

File	Lines	Pattern
microservice-api-gateway/src/routers/quote.controller.ts	81, 133, 415, 909	<code>setImmediate(async () => { try {...} catch (e) { console.error(...)} })</code>
microservice-api-gateway/src/routers/email.controller.ts	65	Same pattern
microservice-api-gateway/src/routers/client-answer.controller.ts	66, 129	Same pattern
microservice-api-gateway/src/auth/auth.controller.ts	234	Same pattern

Remediation: Replace with proper message queue (BullMQ as recommended in DATA_PLATFORM.md).

3.3 Sleep/setTimeout Hacks

Severity: HIGH

File	Line(s)	Hack
microservice-api-gateway/src/lead-square/lead-square.controller.ts	85-86	delay(30000) — 30-second sleep before processing payment webhook
microservice-api-gateway/src/lead-square/lead-square.controller.ts	170-171	Same 30-second delay pattern duplicated
microservice-api-gateway/src/lead-square/services/lsq-bulk-operations.service.ts	610	setTimeout(res, waitMs) — manual rate limiting
microservice-api-gateway/src/lead-square/services/lead-square-lapp.service.ts	60-62	Custom sleep() function
microservice-api-gateway/src/main.ts	101	server.setTimeout(300000) — hardcoded 5-min timeout
All main.ts files (6 services)	Various	setTimeout(() => process.exit(1), 1000) — arbitrary 1s shutdown delay

3.4 Tightly Coupled External Integrations

Severity: MEDIUM

External APIs are called directly from business logic with no abstraction layer:

Integration	Service	Issues
Sibro	Question Service	Hardcoded URLs, 9 repositories injected, no retry mechanism, error emails as “error handling”
LeadSquared	API Gateway	Custom rate limiting via DB tables, scattered across multiple services
Chola Insurance	Common + Question	Direct axios calls, silent error handling (catch + console.log), no timeout config
SendGrid	Email Service	No abstraction, API key set globally without validation
Probe API	API Gateway	Hardcoded URLs in Constants.ts

3.5 Missing Message Queue / Event System

Severity: HIGH

This is well-documented in DATA_PLATFORM.md but worth noting as tech debt:

Current Pattern	Risk
Cron jobs at 4:30 AM IST	Single daily run — failure means 24h wait
30-second sleep after payment webhook	Race condition, arbitrary delay
Manual Sibro master data sync	Human-dependent, can drift
CSV bulk upload at 5 req/sec via custom tables	LsqBulkOperation + LsqBulkOperationResult are hand-rolled queues
ClientEmailScheduler + ClientEmailSchedulerFailures	Hand-rolled job queue in PostgreSQL
Error emails on Sibro failure	No retry, no replay capability

4. Code Quality Debt

4.1 TypeScript Type Safety

Severity: MEDIUM

Issue	Count	Affected Services
any type usage	538+ instances	API Gateway alone; 100+ across all backends
as any type casting	62+ instances	Question Service, Common Service
@ts-ignore directives	30+ files	bi-admin-V2
Untyped function parameters	Widespread	Controllers accepting @Body() data without DTOs
No TypeScript at all	1 app	BK_Web_V2.0 (entire customer portal is JavaScript)

Examples:

```
// Controllers with no input validation
async sendEmailQuote(@Body() data) { ... } // email.controller.ts:44
private async getUserDetailsByQuoteUuid(data: any) { ... } // quote.controller.ts:971

// Unsafe type casting
const sibroError = error as any; // sibro-client.service.ts:473
(global as any).Headers = Headers; // google-cloud-file-upload.service.ts:2

// Entity types
result: any; // probe_search_logs.entity.ts:13
request_body: any; // third-party-api-call-logs.entity.ts
```

4.2 Console Logging in Production

Severity: MEDIUM

120+ files across the platform use `console.log` / `console.error` / `console.warn` instead of a proper logging service. All backend services have a `CloudWatchLoggerService` but it's not used consistently.

Service/App	Files with console.*
API Gateway	21
Question Service	21+
Common Service	15+
Email Service	5
BK_Web_V2.0	27
bi-admin-V2	16
pos/pos-app	23
pos/pos-admin	50+
pos/microservice-pos	5

4.3 Error Handling Anti-Patterns

Severity: HIGH

Empty catch blocks (errors silently swallowed):

File	Line	Context
microservice-email/src/email/email.service.ts	1263	<code>} catch (e) {}</code> — completely empty
microservice-email/src/email/email.service.ts	78-80	<code>} catch { return false; }</code> — hides microservice call failure
microservice-question/src/third-party-service/chola.service.ts	292-293	<code>} catch (e) { console.log(e); }</code> — logs but returns undefined

Background tasks with only `console.error`:

File	Line	Context
microservice-api-gateway/src/routers/quote.controller.ts	106-111	<code>catch (e) { console.error("Error running...", e); }</code>
microservice-api-gateway/src/routers/email.controller.ts	89-91	Same pattern

Promise anti-patterns:

File	Line	Issue
microservice-api-gateway/src/users/users.service.ts	2296	<code>new Promise(async (resolve, reject) => { ... })</code> — unnecessary wrapping

Unsafe regex without null checks:

File	Line	Code
microservice-api-gateway/src/lead-square/lead-square.service.ts	1770	phone?.match(/\d{10}\$/)[0] — crashes if no match
Same file	1789, 1796, 4782	Same unsafe pattern

4.4 Code Duplication

Severity: MEDIUM

Duplicated Pattern	Where	Count
openAPIHeader() HMAC function	BK_Web, bi-admin (2 files), pos-admin, pos-app	5 copies
API_SECRET = "bimakavach-open-api"	6 files across 4 repos	6 copies
delay() / sleep() helper	API Gateway (3 locations)	3 copies
JSON.parse of LSQ custom fields	lead-square.service.ts	10+ copies at lines 1668-1677, 2899, 3756, etc.
Premium calculation / rate tables	quotes.service.ts + tp-calculation.service.ts	2 identical copies
Token refresh logic	bi-admin, BK_Web, pos-admin	3 copies
Chola API header construction	chola.service.ts (5 methods)	5 copies
sendCPMLeadSquared / sendEarLeadSquared	leadsquared.service.ts	Identical method structure
Email sending + template logic	email.service.ts (email service)	sendAllEmails() vs sendFeedbackEmailBulk()
Template render → parse → validate	tp-quote-calculation.service.ts	8+ copies of same pattern

4.5 Unsafe JSON Parsing

Severity: MEDIUM

JSON.parse() called on external/user data without try-catch:

File	Lines
microservice-api-gateway/src/lead-square/lead-square.service.ts	1668-1677, 2899, 3756, 3760, 4305, 4754, 5115, 5119, 5866, 6101
microservice-api-gateway/src/routers/qcr.controller.ts	131

If the data is malformed, the service crashes with an unhandled exception.

4.6 Hardcoded Magic Numbers & Constants

Severity: MEDIUM

File	Line(s)	Value	What it means
microservice-api-gateway/src/routers/quote.controller.ts	100, 155	activityEvent: 336	Unknown LSQ activity type
Same file	159	SchemaName: "mx_Custom_23"	Hardcoded LSQ field mapping
Same file	161	premium * 1.18	GST multiplier — should be configurable
microservice-api-gateway/src/routers/email.controller.ts	71	SchemaName: "mx_Custom_74"	Hardcoded LSQ field
microservice-question/src/third-party-service/chola.service.ts	31	uniqueId = 100000201	Magic starting ID
microservice-question/src/quotes/quotes.service.ts	307	medicalCover = 100000	Hardcoded medical cover
Same file	1769-1793	Rate tables	Hardcoded rate tables for premium calculation
microservice-api-gateway/src/global-constants/Constants.ts	35-141	RENEWAL_PRODUCT_FIELD_MAPPINGS_DATA	Massive hardcoded field mapping array
Same file	9-22	Email addresses	shruti.vishnoi@ , shravan.deshmukh@ , ops@ , cs@ , tejas@ , etc.

4.7 TODO/FIXME Comments

Severity: LOW

File	Line	Comment
microservice-api-gateway/src/users/users.controller.ts	362	//TODO Quote page email verify api
microservice-api-gateway/src/lead-square/lead-square.service.ts	565	// TODO: Find BEST ONE LEAD to Create New Enquire Activity...
Same file	1768	//TODO: email is null but mobile is -> mobile get user -> company
Same file	3594	// TODO: Remark Cross Sell - this will update to lead id
Same file	4696	// TODO: Need to check for lead -> RelatedActivityId??
microservice-api-gateway/src/users/users.service.ts	1043	//TODO move this part and handle in normal way...
microservice-question/src/sibro/services/sibro-client.service.ts	178	// TODO: client_details?.company_details?.entity_ === 'Retail' ? 3 : 4; — incomplete retail vs corporate logic
BK_Web_V2.0/component/v4/CommonButtons/EmailQuoteButton/index.js	30	//TODO Check

4.8 ESLint Suppression

Severity: LOW

Major service files disable important ESLint rules globally:

File	Rules Disabled
lead-square.service.ts	no-unused-vars , no-var-requires , prefer-const
lead-square-lapp.service.ts	Same three rules
data-source.ts	prefer-const , no-var-requires

These mask underlying code quality problems — unused variables that should be removed, `require()` that should be `import` .

5. Dependency Debt

5.1 Deprecated Libraries

Severity: HIGH

Library	Used In	Issue	Replacement
<code>moment.js</code> v2.30.1	API Gateway, Common	Officially in maintenance mode since 2020. 330KB bundle.	<code>dayjs</code> (already used in Email Service) or <code>date-fns</code>
<code>aws-sdk</code> v2	API Gateway	AWS SDK v2 is end-of-life. v3 is also present — dual SDK usage.	Complete migration to <code>@aws-sdk/*</code> v3
<code>crypto-js</code> v4.2.0	pos/pos-app	Deprecated, known vulnerabilities	Built-in <code>crypto</code> or <code>expo-crypto</code>

5.2 Outdated Versions

Severity: MEDIUM

Package	Current	Latest	Service
<code>puppeteer</code>	19.0.0	22+	Question Service, Email Service
<code>next</code>	13.4.19	15+	bi-admin-V2
<code>ejs</code>	3.1.9	3.1.10+	Question Service — known CVEs
<code>@aws-sdk/client-s3</code>	3.400.0	3.700+	API Gateway
<code>axios</code>	1.5.1	1.7+	API Gateway
<code>pdfjs-dist</code>	4.10.38	Latest	Question Service
<code>next-auth</code>	4.24.13	5.x	pos-admin
<code>@nestjs/schedule</code>	4.0.0	Latest	Question Service

5.3 Redundant Dependencies

Severity: LOW

App	Issue
bi-admin-V2	Has both <code>@ant-design/charts</code> AND <code>@tremor/react</code> for charting
bi-admin-V2	Has both <code>antd</code> AND <code>@mui/material</code> for UI components
microservice-email	Has both <code>puppeteer</code> AND <code>@playwright/test</code>
API Gateway	Has both <code>aws-sdk</code> (v2) AND <code>@aws-sdk/*</code> (v3)
Across services	<code>moment.js</code> in some services, <code>dayjs</code> in others — should standardize

6. Frontend-Specific Debt

6.1 No TypeScript in BK Web

Severity: HIGH

The entire customer-facing portal (`BK_Web_V2.0`) is written in plain JavaScript with no TypeScript. This is the primary revenue-generating application.

- No type checking on API responses
- No compile-time error catching
- No IDE autocomplete support
- Missing `@types/react` and `@types/react-dom`

6.2 Missing Error Boundaries

Severity: HIGH

None of the frontend apps implement React Error Boundaries:

App	Error Boundary?	Impact
BK_Web_V2.0	None	Any component crash = white screen for customer
bi-admin-V2	<code>react-error-boundary</code> installed but not used	Admin sees white screen on crash
pos/pos-app	None	Agent app crashes without recovery
pos/pos-admin	None	Admin panel crashes without recovery

6.3 State Management Bloat

Severity: MEDIUM

App	Issue
BK_Web_V2.0	<code>PurchaseFlowContext.js</code> is 2,219 lines — entire purchase flow state in one Context. Business logic mixed with React hooks.
bi-admin-V2	Redux Toolkit with RTK Query, but token refresh logic lives inside <code>prepareHeaders</code> callback (side effect in reducer)

6.4 Mixed UI Libraries in bi-admin

Severity: MEDIUM

bi-admin-V2 uses **four** UI libraries simultaneously: 1. Ant Design (`antd`) 2. Material-UI (`@mui/material` , `@mui/x-data-grid`) 3. Tremor (`@tremor/react`) 4. Tailwind CSS

This results in: - Bloated bundle size - Inconsistent look and feel - Multiple CSS-in-JS runtimes competing

6.5 Missing Accessibility

Severity: MEDIUM

BK_Web_V2.0 (customer portal): - Only ~10 files have `aria-label`, `role=`, or meaningful `alt=` attributes - Most interactive elements lack ARIA attributes - No skip-navigation links - No keyboard navigation testing evident

7. Infrastructure & DevOps Debt

7.1 Outdated Docker Base Images

Severity: HIGH

Node.js 18 reached end-of-life in April 2025. All main services still use it:

Service	Dockerfile Base Image
API Gateway	<code>node:18-slim</code>
Common Service	<code>node:18-slim</code>
Question Service	<code>node:18-slim</code>
Email Service	<code>node:18-slim</code>
Proposal Form Service	<code>node:18-slim</code>
BK Web	<code>node:18.17.0</code> (pinned to specific EOL version)
bi-admin	<code>node:18.16.0</code> (pinned to specific EOL version)

POS services use `node:22` — the rest should migrate.

Unpinned images:

File	Image
<code>reporting-engine-v2/docker-compose.yml</code>	<code>metabase/metabase:latest</code>
<code>reporting-engine/docker-compose-metabase.yml</code>	<code>metabase/metabase:latest</code>
<code>reporting-engine-v2/docker-compose.yml</code>	<code>nginx:alpine</code> (no version)

7.2 Missing Health Checks

Severity: HIGH

9 out of 11 services have **no Docker health check**:

Service	Health Check?
API Gateway	No
Common Service	No
Question Service	No
Email Service	No
Proposal Form Service	No
BK Web	No
bi-admin	No
Reporting Engine	No
Reporting Engine v2	Postgres only
POS API	Yes
POS Admin	Yes

Without health checks, Docker/ECS cannot detect unhealthy containers and auto-restart them.

7.3 Docker Build Issues

Severity: MEDIUM

Issue	Files Affected
Using <code>npm install</code> instead of <code>npm ci</code> (non-deterministic builds)	All 7 Dockerfiles except POS
No multi-stage builds (larger images, dev dependencies in prod)	5 out of 7 main service Dockerfiles
No <code>USER</code> directive (containers run as root)	All main service Dockerfiles

7.4 SSL/TLS Verification Disabled

Severity: HIGH

File	Setting
<code>microservice-email/docker-compose.yml:37</code>	<code>DB_SSL__REJECT_UNAUTHORIZED:false</code>
<code>microservice-api-gateway/docker-compose.yml:45</code>	<code>DB_SSL__REJECT_UNAUTHORIZED:false</code>

This disables certificate validation for database connections, enabling MITM attacks.

7.5 No Secrets Management

Severity: HIGH

The platform has no centralized secrets management: - Secrets are in `.env` files committed to git - No AWS Secrets Manager, HashiCorp Vault, or similar - Credentials hardcoded in source code - No secret rotation policy - GitHub Actions workflows use GitHub Secrets (good), but local dev uses committed `.env` files

8. Testing Debt

Severity: HIGH

Service	Spec Files	Coverage	Notes
API Gateway	Minimal	Unknown	Very few <code>.spec.ts</code> relative to service count
Question Service	Minimal	Unknown	Critical business logic untested
Common Service	Minimal	Unknown	
Email Service	Minimal	Unknown	
Proposal Form Service	Minimal	Unknown	
BK_Web_V2.0	None visible	0%	No test framework configured
bi-admin-V2	None visible	0%	
pos/pos-app	None visible	0%	

No end-to-end tests exist for critical flows (quote → policy → Sibro sync → LSQ update).

9. Priority Matrix

P0 — Fix Immediately (Security)

#	Issue	Effort	Impact
1	Rotate all exposed credentials (AWS, SendGrid, LSQ, Sibro, Firebase, OpenAI, Gemini, etc.)	1 day	Prevents unauthorized access
2	Remove <code>.env</code> files from git history	1 day	Prevents future exposure
3	Delete <code>old-credentials-backup*</code> and <code>playstore-upload-key-BACKUP.jks</code>	10 min	Removes credential files
4	Move hardcoded merchant keys and OAuth secrets to env vars	2 hours	Removes secrets from source
5	Implement secrets manager (AWS Secrets Manager)	3 days	Centralized secret management

P1 — Fix This Sprint (Reliability)

#	Issue	Effort	Impact
6	Add Docker health checks to all services	1 day	Auto-recovery from crashes
7	Upgrade Node.js base images from 18 to 20 LTS	2 days	Security patches, performance
8	Re-enable SSL certificate verification	1 hour	Prevents MITM attacks
9	Replace <code>openssl-legacy-provider</code> + DES encryption	2 days	Modern crypto standards
10	Sanitize all <code>dangerouslySetInnerHTML</code> usage	2 days	Prevents XSS attacks
11	Add Error Boundaries to all frontend apps	1 day	Graceful error recovery

P2 — Fix This Month (Maintainability)

#	Issue	Effort	Impact
12	Split <code>lead-square.service.ts</code> (7,933 lines)	5 days	Maintainability, testability
13	Split <code>quotes.service.ts</code> (4,745 lines)	3 days	Same
14	Split <code>users.service.ts</code> (3,229 lines)	3 days	Same
15	Replace <code>setImmediate</code> fire-and-forget with BullMQ	5 days	Reliable async processing
16	Replace 30-second payment sleep with event-driven flow	2 days	Eliminates race condition
17	Migrate from <code>moment.js</code> to <code>dayjs</code>	2 days	Remove deprecated dependency
18	Complete migration from <code>aws-sdk</code> v2 to v3	3 days	Remove deprecated SDK
19	Add input validation DTOs to all controllers	5 days	Prevent bad data
20	Replace all <code>console.log</code> with <code>CloudWatchLoggerService</code>	3 days	Proper observability

P3 — Fix This Quarter (Quality)

#	Issue	Effort	Impact
21	Add TypeScript to BK_Web_V2.0	2 weeks	Type safety for customer portal
22	Standardize UI libraries in bi-admin (pick one)	2 weeks	Consistent UX, smaller bundle
23	Extract shared auth library (eliminate 5 copies of openAPIHeader)	3 days	DRY, single source of truth
24	Add proper error handling to all catch blocks	5 days	No more silent failures
25	Reduce <code>any</code> type usage — add proper interfaces	1 week	Type safety
26	Wrap <code>JSON.parse</code> calls in try-catch	1 day	Prevent crashes
27	Extract magic numbers to configuration	2 days	Maintainability
28	Use <code>npm ci</code> in all Dockerfiles	1 hour	Deterministic builds
29	Add multi-stage builds to Dockerfiles	1 day	Smaller prod images
30	Add test coverage for critical flows	2 weeks	Confidence in changes